FITBOOK

UAA MI08 · PRODUIRE UN PROJET WEB

CAHIER DES CHARGES.

FitBook — plateforme web de réservation de salles, de cours et de coachs sportifs à Bruxelles.

Mariam Omri
Formation Full-Stack Web Developer · CFItech, Bruxelles
Formateurs : Julien, Yanis, Vitor et Mike · Octobre 2026

SOMMAIRE

01 PRÉSENTATION DU PROJET 4
CONTEXTE 4
OBJECTIFS 4
UTILISATEURS ET RÔLES 4
02 ANALYSE DES BESOINS 6
PERSONAS 6
BENCHMARK CONCURRENTIEL 6
EPICS 7
USER STORIES 8
03 SPÉCIFICATIONS FONCTIONNELLES 11
PAGES DU SITE 11
FONCTIONNALITÉS OBLIGATOIRES ET BONUS 11
RÈGLES DE GESTION 12
04 ANALYSE ET MODÉLISATION 13
MCD — MODÈLE CONCEPTUEL DE DONNÉES 13
MLD — MODÈLE LOGIQUE DE DONNÉES 14
CAS D'UTILISATION 15
DIAGRAMME DE CLASSES 16
05 WEBDESIGN 18
CHARTE GRAPHIQUE 18
DES WIREFRAMES AUX MAQUETTES 18
ÉCRANS PRINCIPAUX 20
COMPOSANT « SWATCH » (FIGMA) 24
PROTOTYPE 24
06 ARCHITECTURE TECHNIQUE 26
FRONTEND (ANGULAR) 26
BACKEND (SYMFONY + MYSQL) 26
07 TESTS, SÉCURITÉ ET QUALITÉ 27
08 GESTION DE PROJET 28
VALIDATION AVANT DÉVELOPPEMENT 28
PRÉSENTATION FINALE 28
09 SÉCURITÉ : ANALYSE DES RISQUES ET CONTRE-MESURES 29
AUTHENTIFICATION ET PERMISSIONS 29
PROTECTION DES DONNÉES ET DE LA CONFIGURATION 29
ATTAQUES CONNUES ET CONTRE-MESURES 29
TESTS DE L'API (POSTMAN / NEWMAN) 31
SAUVEGARDE ET CONTINUITÉ 31
CONCLUSION 31
10 LISTE DES TESTS 32

AUTHENTIFICATION ET COMPTE..... 32
ESPACE SPORTIF..... 32
ESPACE COACH..... 33
ESPACE SALLE / GESTIONNAIRE..... 33
ESPACE ADMINISTRATEUR..... 33
SÉCURITÉ ET PERMISSIONS..... 33
API ET PERFORMANCE..... 34

Astuce : dans Word, clic droit sur le sommaire → « Mettre à jour les champs » pour actualiser les numéros de page.

LIENS DU PROJET

Trello : trello.com/b/RnNUL2B7/fitbook

GitHub : github.com/Mariamomri/FitBook

Site (Vercel) : fit-book-tau.vercel.app

Maquette Figma : figma.com — prototype FitBook

Présentation Canva : canva.link/klx9lgboonqv952

01 PRÉSENTATION DU PROJET

CONTEXTE

FitBook est une plateforme web dédiée au sport à Bruxelles. Elle permet de rechercher des salles, des cours et des coachs, puis de réserver une séance en quelques clics. Les professionnels — coachs indépendants et gestionnaires de salle — disposent d'un espace pour gérer leurs activités, leurs disponibilités et leurs réservations.

Le projet est réalisé dans le cadre de l'UAA MI08 « Produire un projet Web » (CFItech). Il couvre les comptes utilisateurs, la recherche avec filtres avancés, les rôles, les opérations CRUD, l'administration, la validation des formulaires et la gestion des données.

> ***OBJECTIF GÉNÉRAL***
>
> Développer une nouvelle application web au **design moderne, responsive et ergonomique**, qui permet de **trouver rapidement** une salle, un cours ou un coach, de **réserver et gérer** ses activités (séances, disponibilités, calendrier, réservations, favoris, avis) dans un cadre **sécurisé** (confirmation email, permissions par rôle, administration des contenus).

OBJECTIFS

N°	Objectif	Ce que cela signifie pour FitBook
1	Design moderne, responsive et ergonomique	Interface claire, identique en esprit sur mobile, tablette et desktop ; vocabulaire et visuels propres au sport.
2	Recherche efficace	Barre de recherche + filtres (activité, ville, date, prix, places libres) pour trouver une salle, un cours ou un coach.
3	Réservation et gestion des activités	Séances, disponibilités, calendrier, réservations, favoris et avis.
4	Sécurité et administration	Authentification avec confirmation email, permissions par rôle, modération et administration des contenus.

UTILISATEURS ET RÔLES

FitBook distingue un visiteur anonyme et quatre rôles connectés. Chaque rôle accède à un dashboard adapté ; les permissions sont contrôlées côté backend.

Rôle	Ce qu'il peut faire	Droits
Visiteur	Rechercher, filtrer, consulter les fiches salle / coach / séance, créer un compte.	Lecture seule
Sportif	Gérer son profil, réserver et annuler, consulter son historique et son calendrier, gérer ses favoris, publier des avis et des notes, choisir la couleur du site.	CRUD sur ses réservations, favoris et avis
Coach	Gérer son profil professionnel, ses séances et ses	CRUD sur ses

Rôle	Ce qu'il peut faire	Droits
	disponibilités, voir ses inscrits, son calendrier et ses avis.	séances et disponibilités
Gestionnaire de salle	Gérer les informations de la salle, les cours, horaires, capacités, le calendrier, les réservations et consulter les avis.	CRUD sur ses salles et cours
Administrateur	Gérer utilisateurs, salles, coachs, activités et réservations, modérer les avis, voir les statistiques, lancer une sauvegarde.	CRUD total

02 ANALYSE DES BESOINS

PERSONAS



SARA · LA SPORTIVE RÉGULIÈRE

PROFIL
28 ans, chargée de communication, célibataire, habite Ixelles (Bruxelles).

OBJECTIF PRINCIPAL
Trouver et réserver rapidement un cours près de chez elle, depuis son smartphone.

BESOINS
Rechercher par discipline et par horaire, voir les places restantes, annuler facilement, retrouver ses séances favorites, lire les avis avant de réserver.

FRUSTRATION
Elle doit écrire ou appeler les salles pour savoir s'il reste de la place, et elle oublie ses réservations.

COMPORTEMENT DIGITAL
iPhone, à l'aise avec les applications de réservation ; consulte les notes des autres utilisateurs avant de choisir.



SAMI · LE COACH INDÉPENDANT

PROFIL
36 ans, coach sportif indépendant, marié, un enfant, habite Schaerbeek (Bruxelles).

OBJECTIF PRINCIPAL
Publier ses séances et suivre les réservations sans passer par des messages dispersés.

BESOINS
Créer et modifier ses séances, voir qui est inscrit, gérer ses disponibilités, consulter les avis reçus.

FRUSTRATION
Les inscriptions arrivent par WhatsApp et SMS : il ne sait pas à l'avance combien de personnes viendront.

COMPORTEMENT DIGITAL
Ordinateur au bureau et smartphone en déplacement ; très à l'aise avec le numérique.

BENCHMARK CONCURRENTIEL

Trois façons de réserver une activité sportive à Bruxelles ont été comparées, pour identifier ce que FitBook doit reprendre et ce qu'il doit faire autrement.

Solution	Principe	Points forts	Limites pour nos personas	Ce que FitBook retient
ClassPass	Abonnement à crédits utilisables dans de nombreux studios et salles.	Offre très large, réservation rapide depuis l'application.	Modèle par abonnement ; peu centré sur les coachs indépendants.	Réservation en quelques clics, places restantes visibles.
Urban Sports Club	Abonnement mensuel donnant accès à de nombreux partenaires (fitness, escalade, boxe...), présent à Bruxelles.	Grande variété de sports, présence locale.	Abonnement obligatoire ; fiches coach peu mises en avant.	Recherche par discipline et par ville, carte des salles.
Réservation directe	Site de la salle, téléphone, WhatsApp ou SMS.	Contact direct avec la salle ou le coach.	Informations dispersées, pas de vue sur les places, oublis (frustrations de Sara et Sami).	Centraliser les réservations, rappel par email 24 h avant.

POSITIONNEMENT DE FITBOOK

Réservation **à la séance, sans abonnement**, sur une seule plateforme qui réunit **salles et coachs indépendants**, avec des **avis vérifiés** (liés à une participation réelle) et une interface **personnalisable** (couleur du site).

EPICS

Epic	Titre	Description
E1	Design moderne, responsive et ergonomique	Interface claire, cohérente et adaptée à chaque rôle, utilisable sur mobile, tablette et desktop, avec un vocabulaire et des structures visuelles propres au sport.
E2	Compte, authentification et permissions	Inscription avec confirmation par email, connexion / déconnexion sécurisées, dashboard adapté au rôle. Permissions contrôlées côté backend. Sans cette epic, aucune autre n'est accessible.
E3	Recherche et découverte	Trouver rapidement une salle, un cours ou un coach grâce à la barre de recherche et aux filtres, et consulter l'offre sans compte.
E4	Réservation et calendrier	Consulter les disponibilités dans un calendrier, réserver et annuler, recevoir une confirmation par email, retrouver ses réservations à venir et passées. C'est le cœur métier.
E5	Favoris, avis et notes	Enregistrer ses favoris, noter et commenter une séance suivie,

Epic	Titre	Description
		et permettre à tous de consulter ces avis pour choisir en confiance.
E6	Espace coach	Créer, modifier et supprimer ses séances, définir ses disponibilités, suivre ses inscrits et ses avis, piloter son activité depuis un dashboard.
E7	Espace gestionnaire de salle	Créer, modifier et supprimer ses salles, suivre leurs réservations et leur occupation, bloquer des créneaux quand une salle est indisponible.
E8	Administration	Gestion complète de la plateforme (CRUD total) : utilisateurs, rôles, séances, salles et avis, avec un dashboard de suivi.

USER STORIES

Format : **En tant que** [rôle], **je veux** [action] **afin de** [bénéfice].

Visiteur (anonyme)

ID	User story	Epic
US01	En tant que visiteur, je veux rechercher des salles, des cours et des coachs avec une barre de recherche, afin de trouver vite ce qui m'intéresse.	E3
US02	En tant que visiteur, je veux filtrer les séances (activité, ville, date, prix, places libres), afin d'affiner ma recherche.	E3
US03	En tant que visiteur, je veux consulter la fiche d'une salle, d'un coach ou d'une séance, afin de choisir mon cours.	E3
US04	En tant que visiteur, je veux créer un compte et confirmer mon email, afin de pouvoir me connecter.	E2

Sportif

ID	User story	Epic
US05	En tant que sportif, je veux me connecter et modifier mon profil, afin de gérer mes informations personnelles et mes préférences.	E2
US06	En tant que sportif, je veux réserver une séance, afin de garantir ma place pour l'activité choisie.	E4
US07	En tant que sportif, je veux annuler ma réservation, afin de libérer la place pour un autre utilisateur.	E4
US08	En tant que sportif, je veux voir l'historique de mes réservations, afin de suivre mes activités passées et planifiées.	E4
US09	En tant que sportif, je veux voir mon calendrier de réservations, afin de visualiser mes séances et organiser mon emploi du temps sportif.	E4

ID	User story	Epic
US10	En tant que sportif, je veux ajouter une salle, un coach ou un cours à mes favoris, afin de retrouver facilement mes préférences.	E5
US11	En tant que sportif, je veux noter et commenter une salle, un coach ou une séance que j'ai suivie, afin de partager mon avis et aider les autres à choisir.	E5
US12	En tant que sportif, je veux modifier ou supprimer mes avis, afin de corriger ou retirer mon commentaire.	E5
US13	En tant que sportif, je veux choisir la couleur du site à l'inscription ou dans mon profil, afin de personnaliser mon interface.	E1

Coach

ID	User story	Epic
US14	En tant que coach, je veux gérer mon profil professionnel, afin de présenter mes compétences et mes services aux sportifs.	E6
US15	En tant que coach, je veux créer, modifier et supprimer mes séances, afin d'organiser mon planning et proposer mes cours.	E6
US16	En tant que coach, je veux indiquer les jours et les heures où je suis disponible, afin de donner des séances.	E6
US17	En tant que coach, je veux voir mon calendrier et la liste des inscrits à chaque séance, afin de préparer mes cours et suivre la participation.	E6
US18	En tant que coach, je veux consulter les avis laissés sur moi, afin d'améliorer mes prestations.	E6

Gestionnaire de salle

ID	User story	Epic
US19	En tant que gestionnaire, je veux enregistrer et modifier les informations de ma salle (adresse, horaires, contact), afin de garder des données à jour.	E7
US20	En tant que gestionnaire, je veux créer des séances dans ma salle, avec ou sans coach, et fixer la capacité, afin d'organiser les activités.	E7
US21	En tant que gestionnaire, je veux voir le calendrier et les réservations de ma salle, afin de suivre l'occupation et planifier les disponibilités.	E7
US22	En tant que gestionnaire, je veux consulter les avis sur ma salle, afin d'évaluer la satisfaction et améliorer le service.	E7

Administrateur

ID	User story	Epic
US23	En tant qu'administrateur, je veux lister, désactiver et supprimer des utilisateurs, afin de maintenir une plateforme saine.	E8

ID	User story	Epic
US24	En tant qu'administrateur, je veux modérer les avis, afin de retirer les contenus inappropriés ou non conformes.	E8
US25	En tant qu'administrateur, je veux voir des statistiques globales, afin d'analyser l'activité de la plateforme.	E8
US26	En tant qu'administrateur, je veux lancer une sauvegarde de la base, afin de sécuriser les données.	E8

03 SPÉCIFICATIONS FONCTIONNELLES

PAGES DU SITE

Espace	Pages
Public	Accueil · Recherche d'activités (filtres) · Salles (liste + carte) · Fiche salle · Fiche coach · Fiche séance · Contact
Compte	Inscription (avec choix de la couleur du site) · Vérification de l'email · Compte confirmé · Connexion · Mot de passe oublié · Nouveau mot de passe · Profil · Modifier le profil
Sportif	Dashboard sportif · Mes réservations · Historique (+ laisser un avis) · Favoris · Réservation confirmée
Coach	Dashboard coach · Profil professionnel · Nouvelle séance · Disponibilités
Salle	Dashboard salle · Ma salle (cours, horaires, capacités)
Administrateur	Dashboard admin · Ajouter un utilisateur · Modération (suppression avec confirmation)
Emails	Réservation confirmée · Rappel 24 h avant la séance · Séance annulée par le coach

Toutes les pages existent en trois versions : **mobile (390 px), tablette (834 px) et desktop (1440 px)**, avec une approche mobile-first.

FONCTIONNALITÉS OBLIGATOIRES ET BONUS

Fonctionnalité	Description	Statut
Barre de recherche + filtres	Recherche par activité, salle ou coach ; filtres activité, ville, date, prix, places libres.	Obligatoire
Favoris	Ajouter / retirer une salle, un cours ou un coach de ses favoris.	Obligatoire
Avis et notes	Note de 1 à 5 étoiles + commentaire sur une salle, un coach ou une séance suivie ; modification et suppression de son avis ; modération par l'admin.	Obligatoire
Calendrier	Calendrier des réservations (sportif), des séances et disponibilités (coach), de l'occupation (salle).	Obligatoire
Carte interactive	Vue « liste + carte » des salles et bouton « Ma position ».	Bonus
Notifications	Email de rappel 24 h avant la séance.	Bonus
QR code	QR code de confirmation à présenter à l'accueil.	Bonus
Couleur du site	Choix parmi 6 couleurs d'accent (vert, orange, jaune, bleu, rose, rouge).	Créativité

RÈGLES DE GESTION

Réf.	Règle
RG01	L'email est unique. Après l'inscription, le compte reste **inactif** tant que l'email n'est pas confirmé (lien valable 24 h).
RG02	Mot de passe : 8 caractères minimum, 1 majuscule, 1 chiffre. Il est stocké **haché** (Symfony PasswordHasher), jamais en clair.
RG03	L'inscription publique est réservée aux sportifs. Les comptes coach et salle sont créés par l'administrateur, qui envoie une invitation par email.
RG04	Une réservation est refusée si la séance est **complète** (capacité atteinte) : le sportif peut alors rejoindre la liste d'attente.
RG05	Une réservation peut être annulée tant que l'annulation est autorisée (méthode estAnnulable()). La place libérée redevient disponible.
RG06	Emails automatiques : confirmation de réservation, rappel 24 h avant, annulation d'une séance par le coach.
RG07	Un avis est toujours lié à une **réservation passée** (« Participation vérifiée ») : **1 avis maximum par réservation**. Note de 1 à 5, commentaire de 500 caractères maximum.
RG08	Une fois l'avis publié, le formulaire « Donner mon avis » est remplacé par l'avis du sportif, avec les actions **Modifier** et **Supprimer**. Les maquettes montrent ces deux états sur le même écran pour présenter la fonctionnalité complète.
RG09	La note d'une salle, d'un coach ou d'un cours est la **moyenne des avis** des séances concernées (calculerNoteMoyenne()).
RG10	L'administrateur peut masquer ou supprimer un avis non conforme (statut_avis, méthode masquer()).
RG11	La couleur choisie est enregistrée dans le profil et appliquée aux boutons, liens et accents (variable CSS --accent). Valeur par défaut : vert lime.
RG12	Tous les formulaires sont validés **côté backend**, avec des messages d'erreur clairs. Le formulaire de contact est validé par un **JSON Schema**.

04 ANALYSE ET MODÉLISATION

Les modèles ont été réalisés avec **JMerise** (MCD, MLD) et **StarUML** (cas d'utilisation, diagramme de classes).

MCD — MODÈLE CONCEPTUEL DE DONNÉES

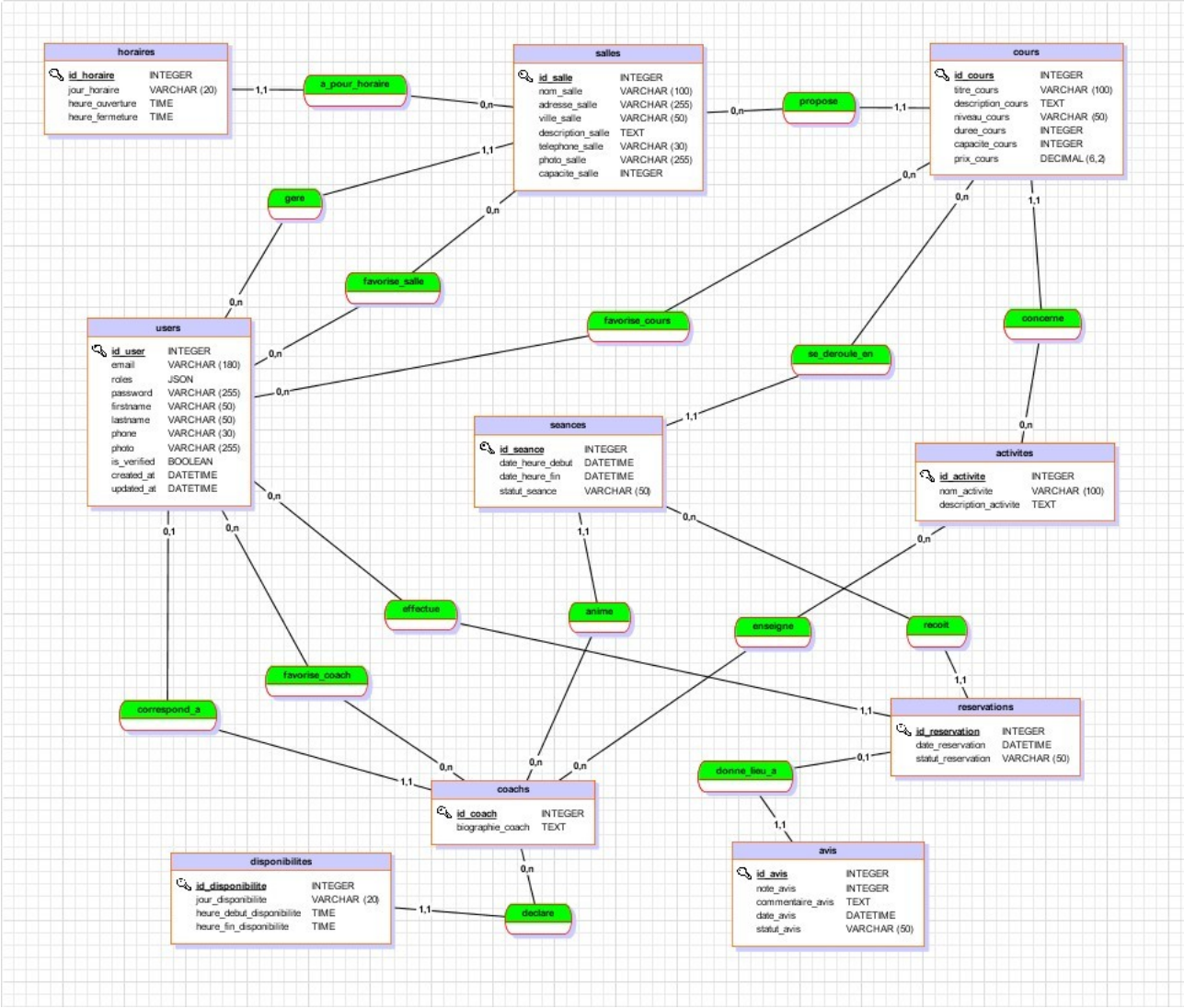


Figure 1 — MCD de FitBook (JMerise)

Types de relations

Type	Exemple dans FitBook	Lecture
Un à un (1:1)	users — correspond_a — coachs (0,1 / 1,1)	Un utilisateur a au plus un profil coach ; un profil coach appartient à un seul utilisateur.
Un à un (1:1)	reservations — donne_lieu_a — avis (0,1 / 1,1)	Une réservation donne lieu à 0 ou 1 avis ; un avis concerne exactement une réservation.

Type	Exemple dans FitBook	Lecture
Un à plusieurs (1:n)	salles — propose — cours (0,n / 1,1)	Une salle propose plusieurs cours ; un cours appartient à une seule salle.
Un à plusieurs (1:n)	coachs — anime — seances (0,n / 1,1)	Un coach anime plusieurs séances ; une séance est animée par un seul coach.
Un à plusieurs (1:n)	users — effectue — reservations (0,n / 1,1)	Un utilisateur effectue plusieurs réservations ; une réservation appartient à un seul utilisateur.
Plusieurs à plusieurs (n:n)	users — favorise_salle — salles (0,n / 0,n)	Un utilisateur a plusieurs salles favorites ; une salle est favorite de plusieurs utilisateurs. Idem pour favorise_cours et favorise_coach.
Plusieurs à plusieurs (n:n)	coachs — enseigne — activites (0,n / 0,n)	Un coach enseigne plusieurs activités ; une activité est enseignée par plusieurs coachs.
Un à un (1:1)	users — posséder — cartes_membre (0,1 / 1,1)	Un utilisateur possède au plus une carte de membre ; une carte de membre appartient à un seul utilisateur.
Un à plusieurs (1:n)	users — demander — reset_password_request (1,1 / 0,n)	Un utilisateur peut faire plusieurs demandes de réinitialisation de mot de passe ; chaque demande appartient à un seul utilisateur.

MLD — MODÈLE LOGIQUE DE DONNÉES

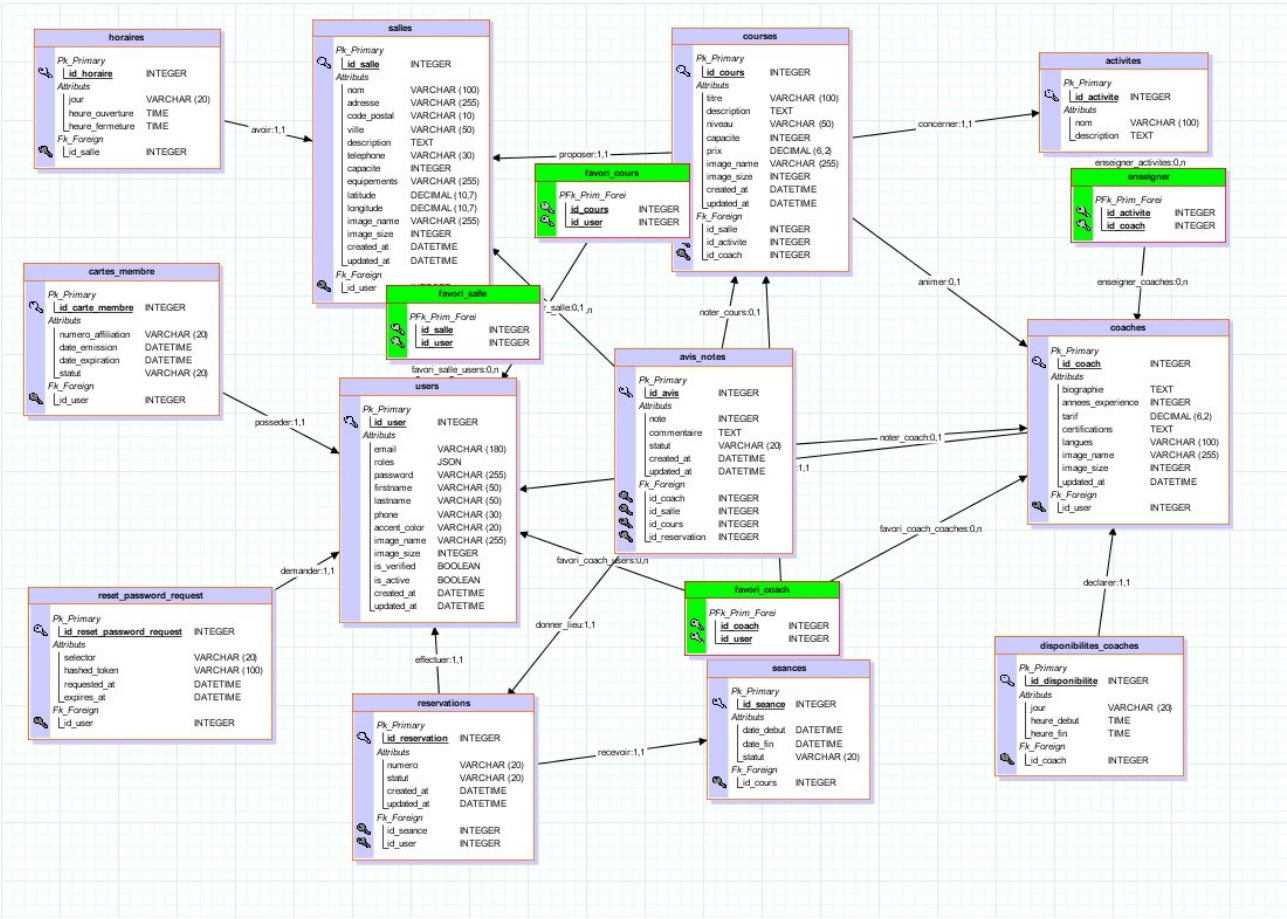


Figure 2 — MLD de FitBook (JMerise)

Passage du MCD au MLD : les relations **1:n** deviennent des clés étrangères (par exemple id_salle dans cours, id_coach dans seances) ; les relations **n:n** deviennent des tables d'association avec une clé primaire composée (favorise_salle, favorise_cours, favorise_coach, enseigne).

CAS D'UTILISATION

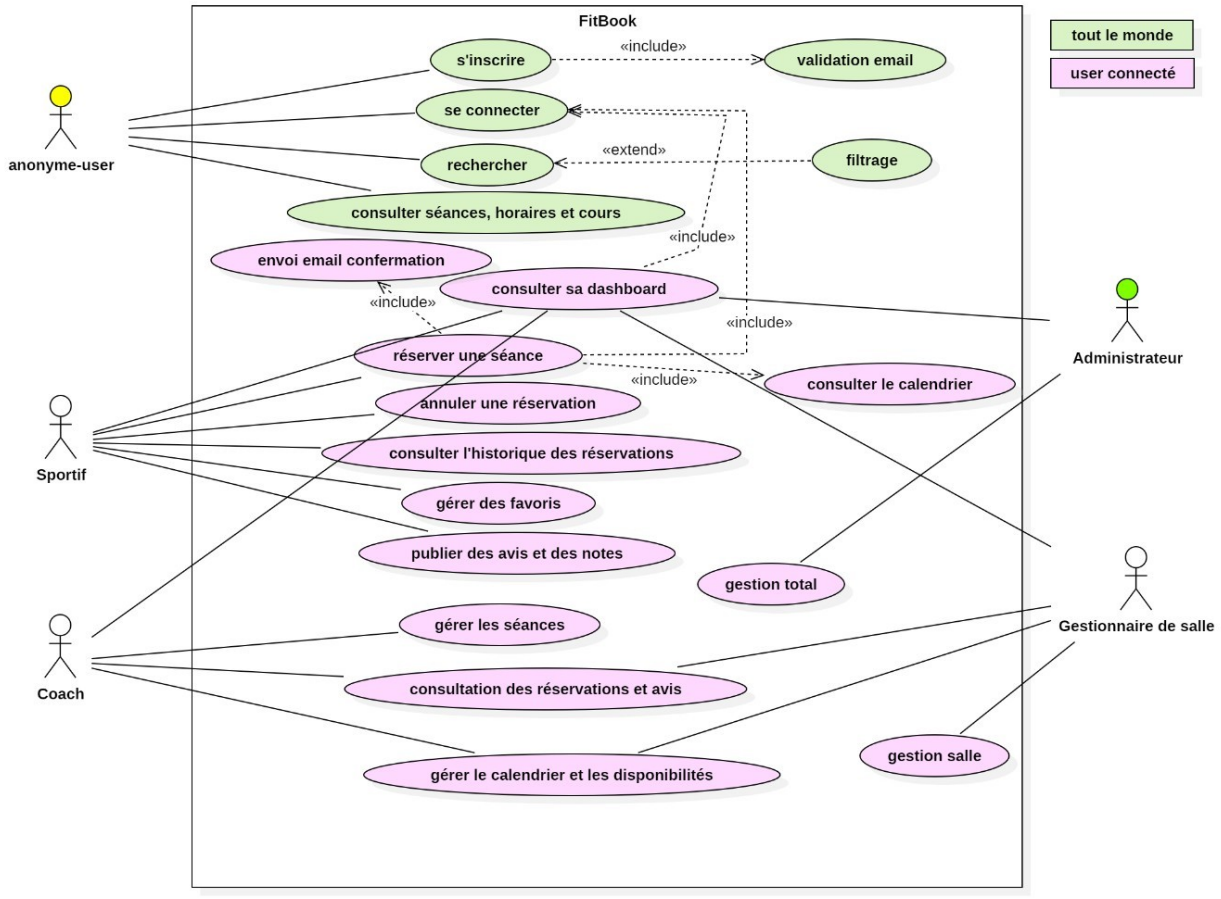


Figure 3 — Diagramme des cas d'utilisation (StarUML)

- **«include»** : « s'inscrire » inclut toujours « validation email » ; « réserver une séance » inclut « se connecter », « consulter le calendrier » et « envoi email de confirmation ».
- **«extend»** : « filtrage » étend « rechercher » (étape optionnelle).

DIAGRAMME DE CLASSES

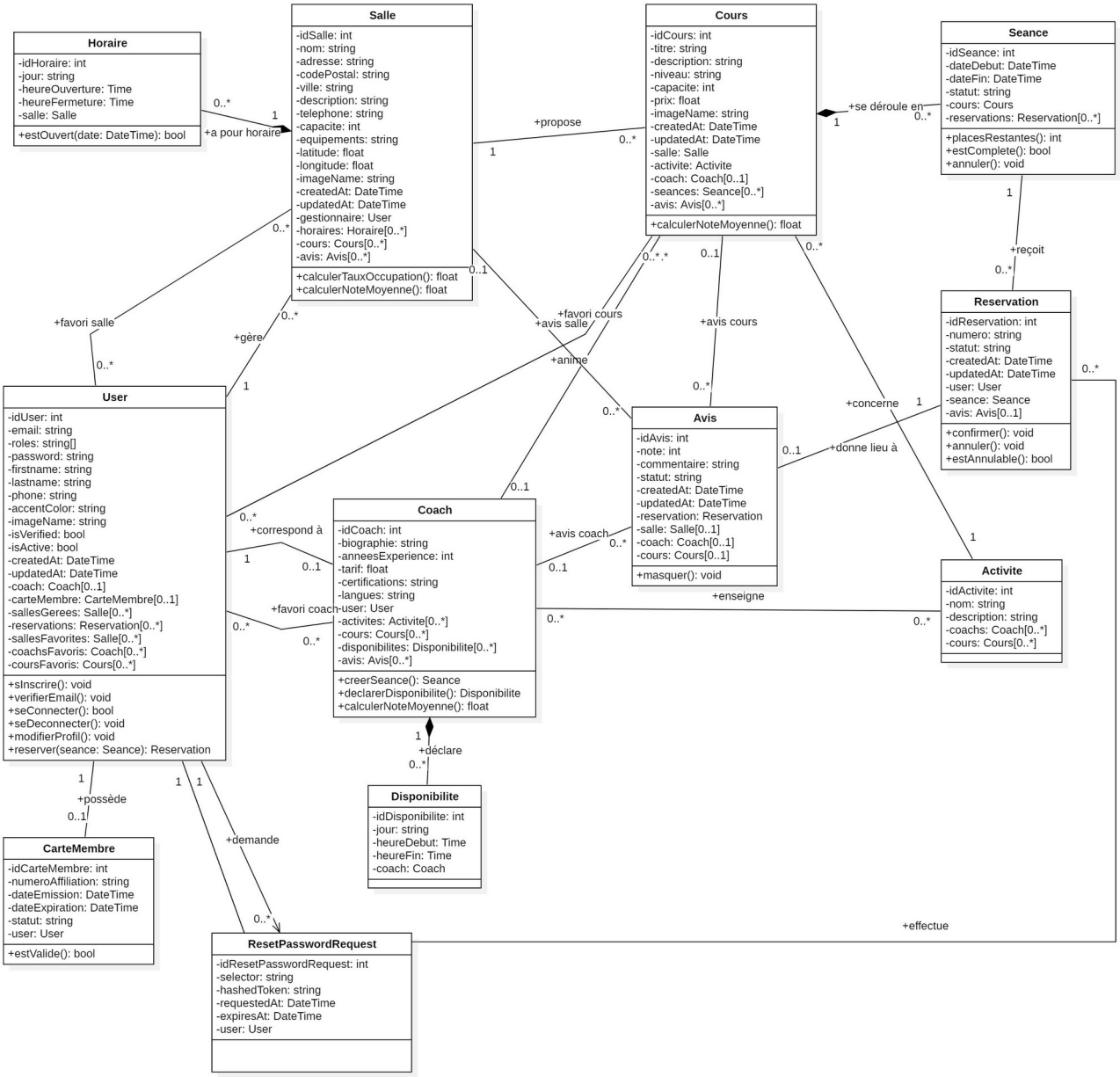


Figure 4 — Diagramme de classes (StarUML)

Les méthodes métier traduisent les règles de gestion : placesRestantes() et estComplete() (capacité), estAnnulable() (annulation), calculerNoteMoyenne() (notes), masquer() (modération).

05 WEBDESIGN

CHARTE GRAPHIQUE

Univers **sombre et sportif**, avec un accent **vert lime** énergique. Les titres sont en lettres capitales condensées et en italique pour donner du mouvement.

	Couleur	Code	Usage
	Noir FitBook	#0A0A0A	Fond principal du site
	Gris carte	#151518	Cartes, formulaires, menus
	Vert lime (accent)	#A6FF00	Boutons, liens, éléments actifs
	Blanc	#FFFFFF	Titres et textes principaux
	Gris clair	#A6A6AF	Textes secondaires
	Rouge	#EA4335	Erreurs, suppression

Usage	Police	Style
Titres	Barlow Condensed	ExtraBold, italique, majuscules
Textes, boutons, formulaires	Inter	Regular, Medium, Bold

Les utilisateur peut remplacer le vert lime par l'une des **6 couleurs d'accent** : vert, orange, jaune, bleu, rose ou rouge (voir RG11).

DES WIREFRAMES AUX MAQUETTES

Démarche : **zoning et wireframes** en niveaux de gris (structure et contenus), puis **maquettes** haute fidélité, puis **prototype** cliquable dans Figma. Chaque écran est décliné en **desktop, tablette et mobile**.

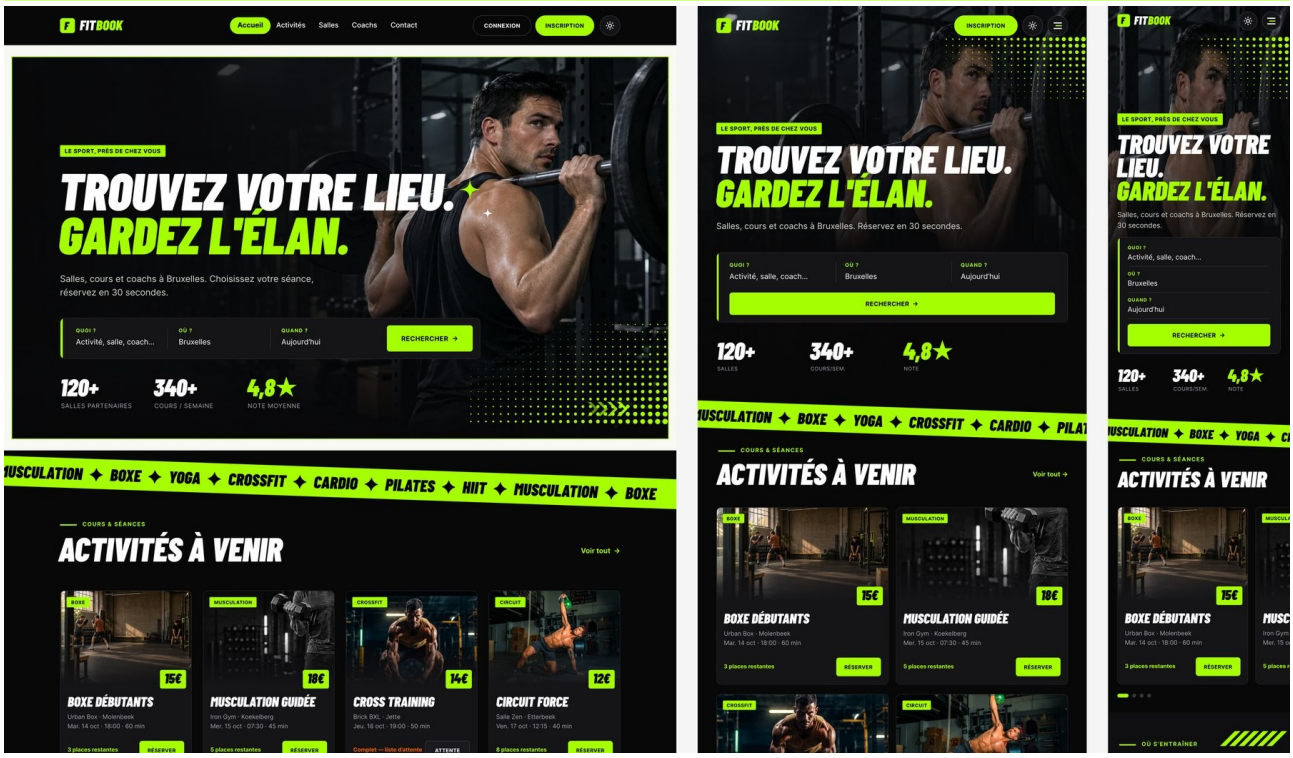


Figure 5 — Page d'accueil en desktop, tablette et mobile

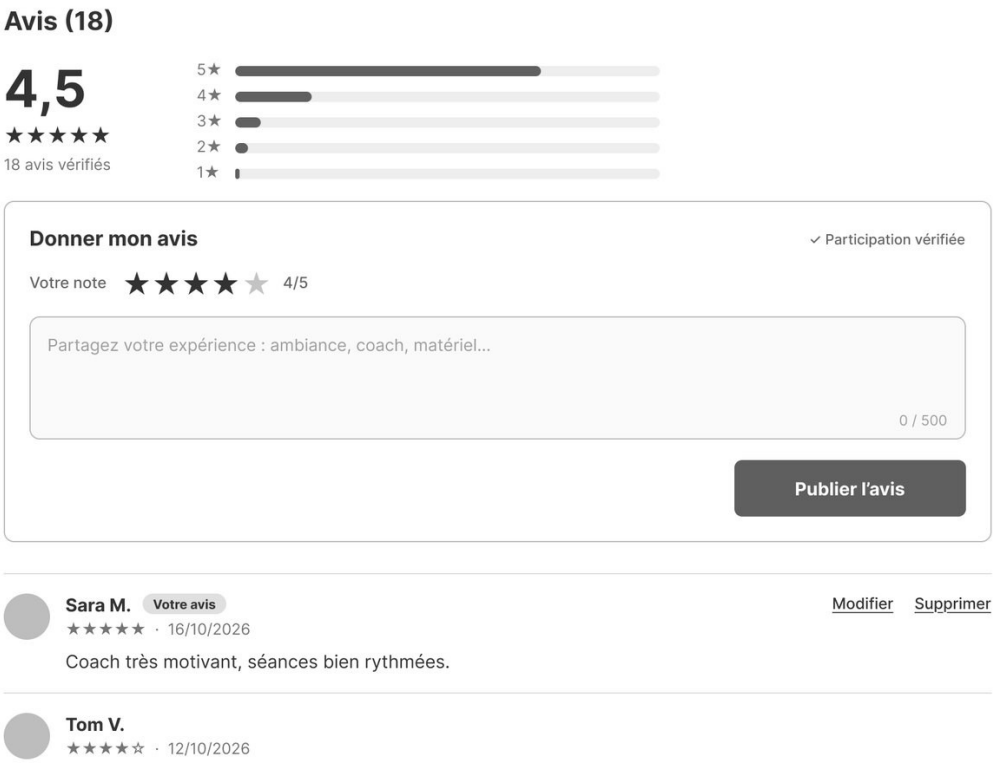


Figure 6 — Wireframe — section « Avis » d'une fiche salle

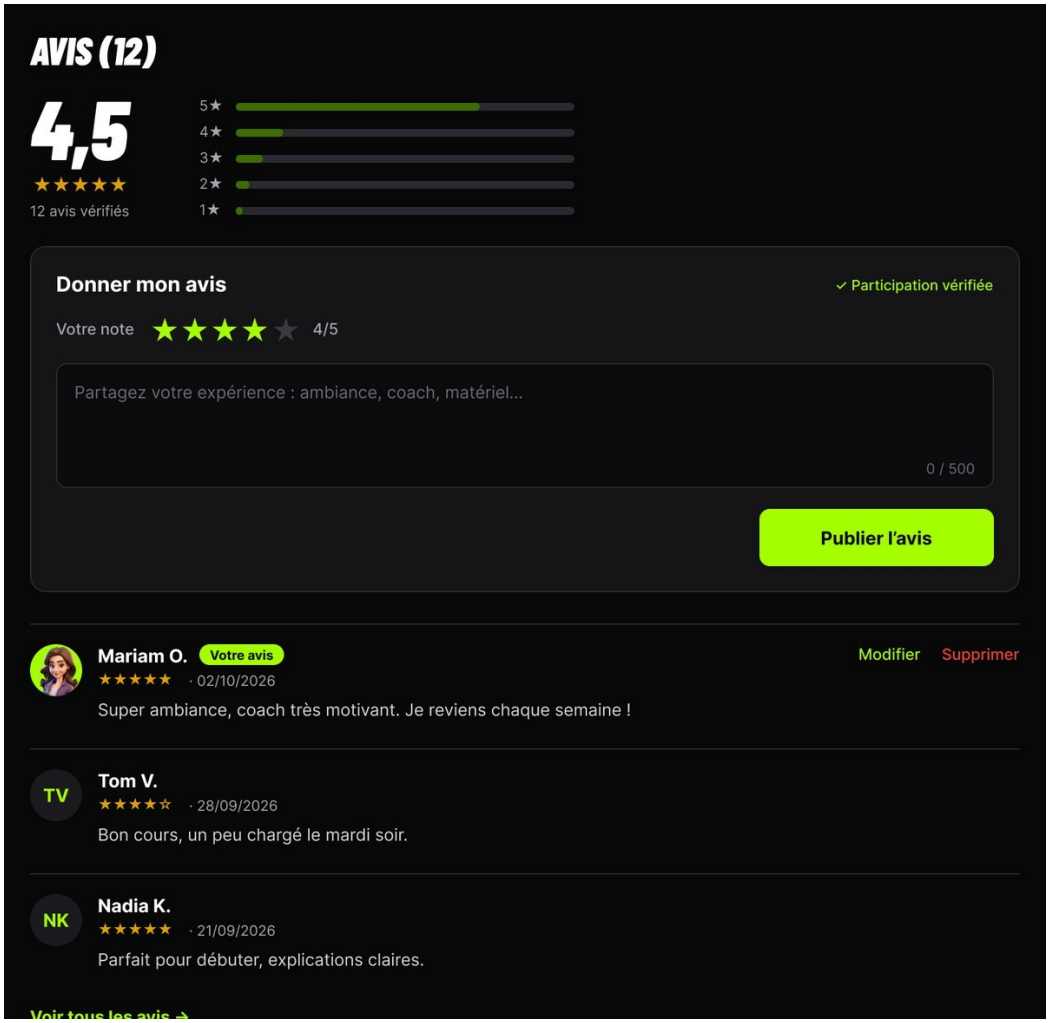


Figure 7 — Maquette — avis et notes : formulaire, « Participation vérifiée », Modifier / Supprimer

ÉCRANS PRINCIPAUX

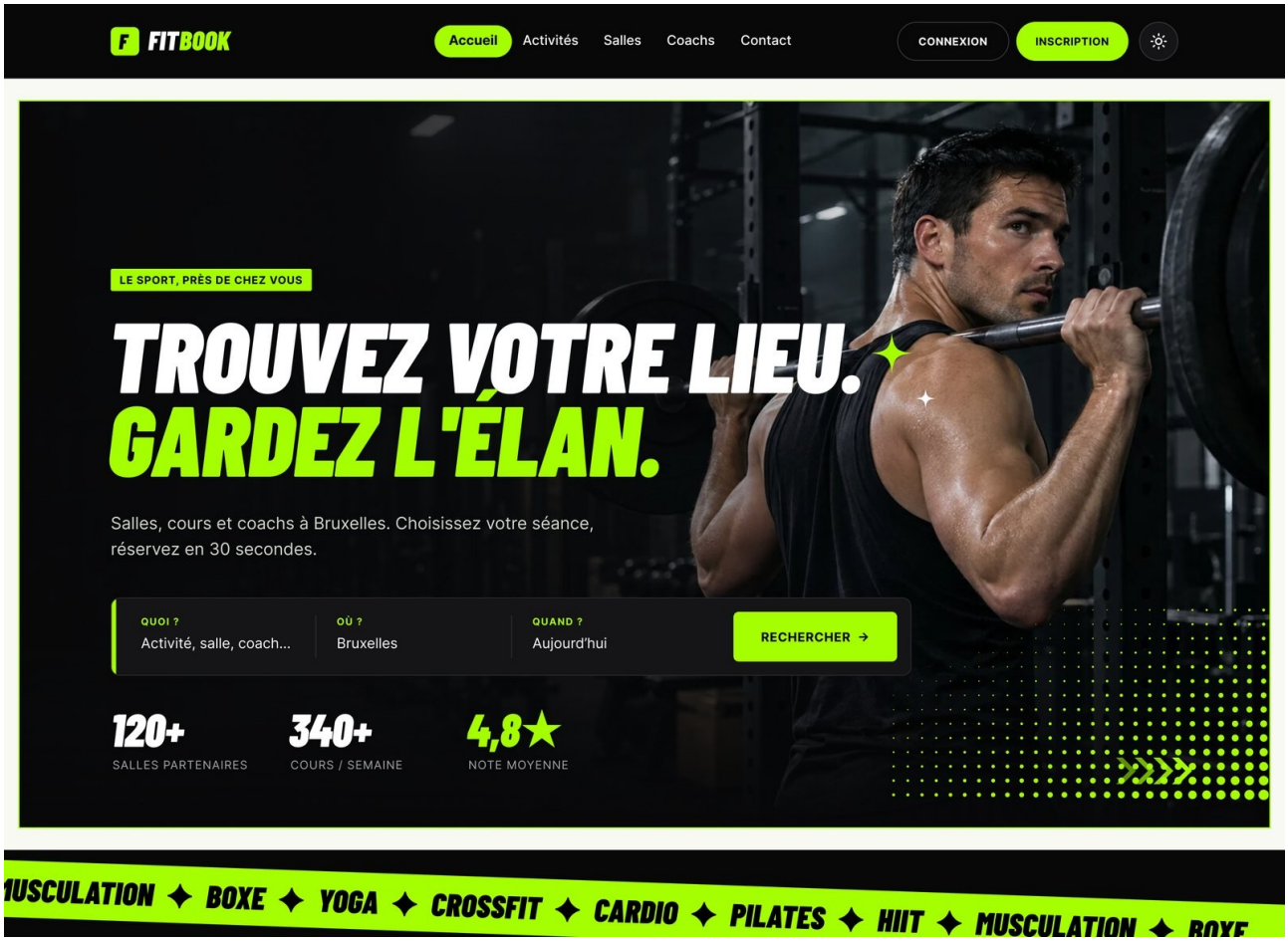


Figure 8 — Accueil (desktop)

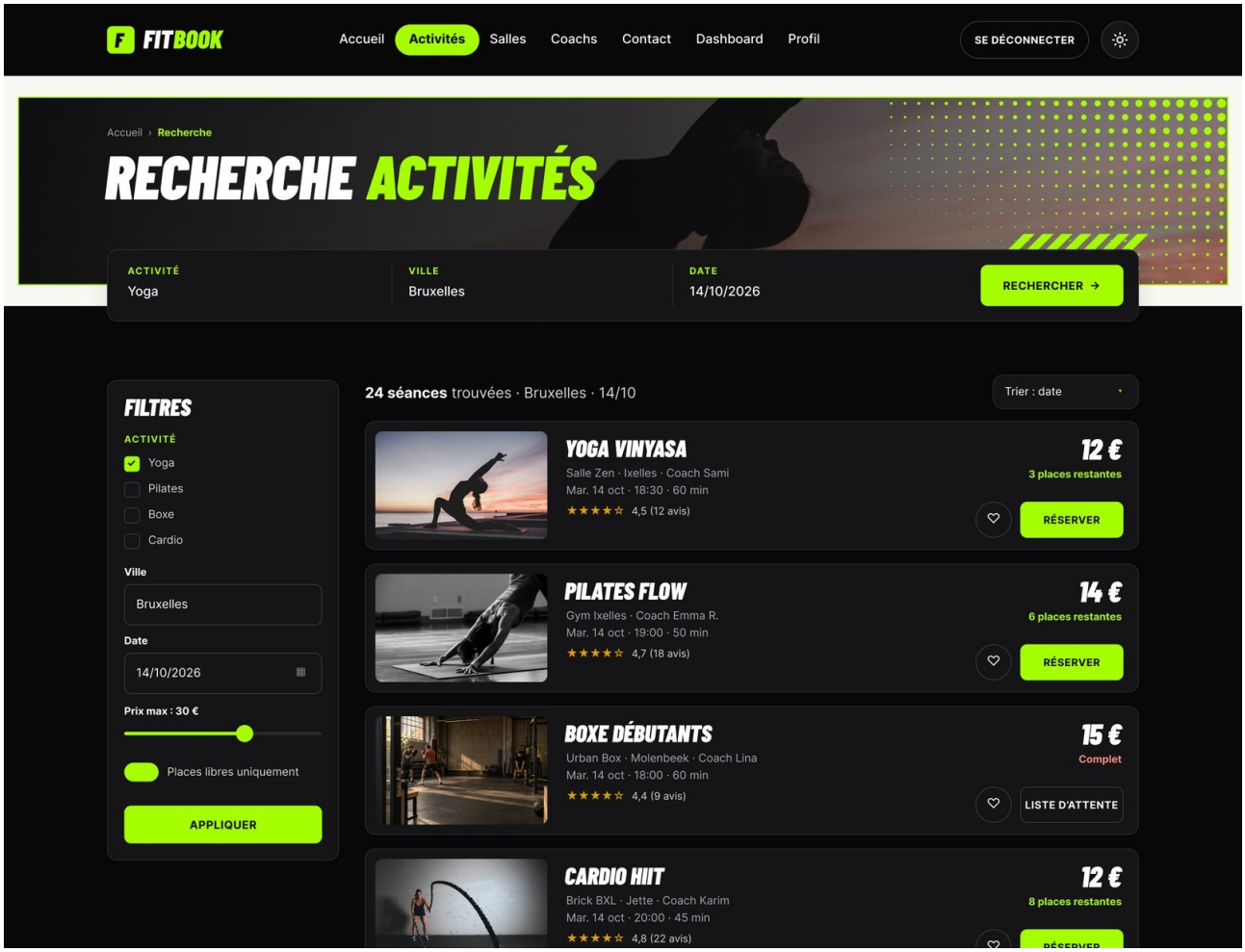


Figure 9 — Recherche d'activités avec filtres (desktop)



Figure 10 — Inscription : choix de la couleur du site (vert, orange, bleu)

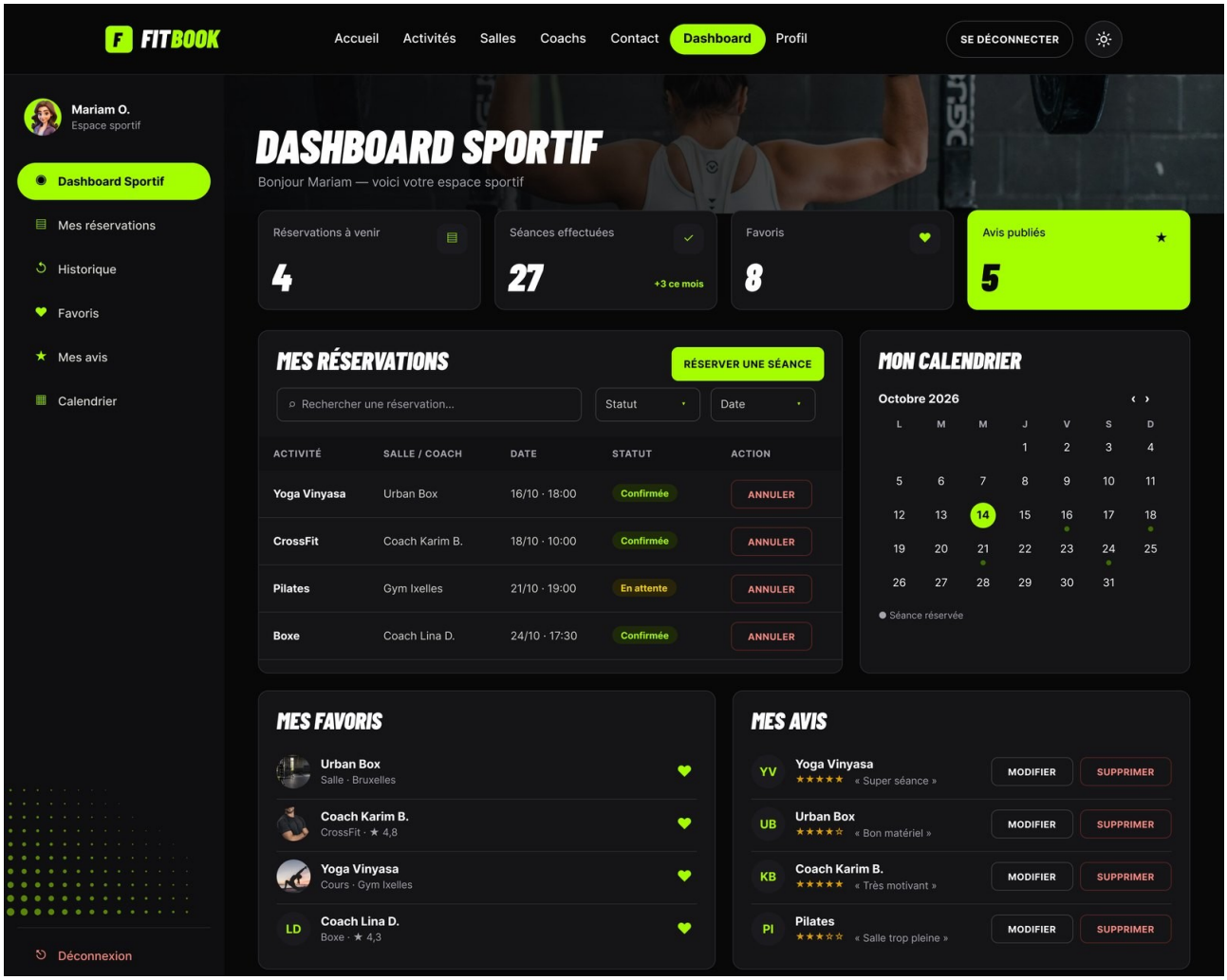


Figure 11 — Dashboard sportif (desktop)

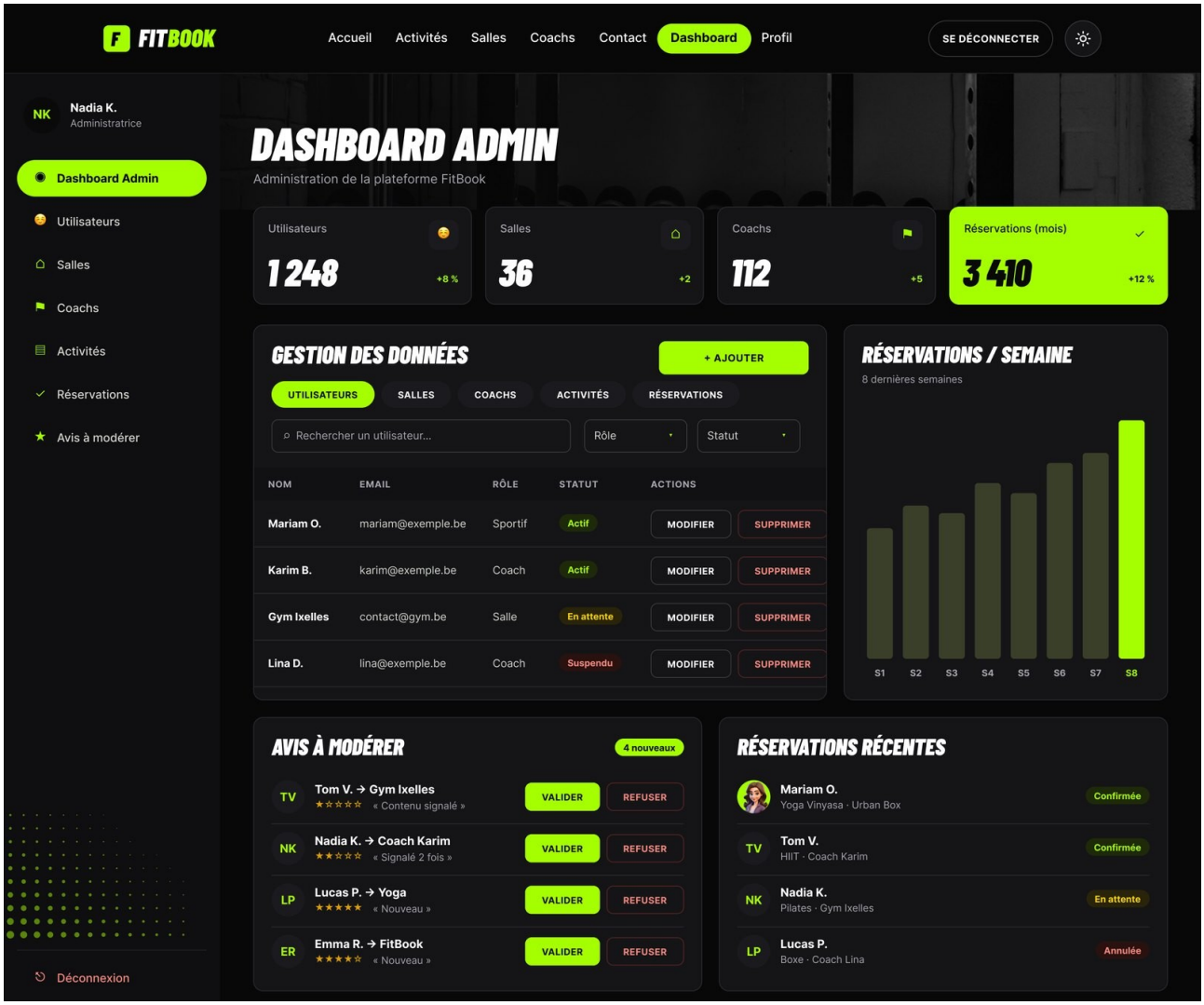


Figure 12 — Dashboard administrateur (desktop)

COMPOSANT « SWATCH » (FIGMA)

Un **composant** est un élément réutilisable : il est créé une fois, puis placé dans les maquettes sous forme d'**instances**. Une modification du composant principal se répercute sur toutes les instances.

Le composant **Swatch** (bouton de couleur) possède deux **variantes** : « Par défaut » et « Sélectionné » (bordure de la couleur + coche). Il est utilisé pour les 6 couleurs de la page d'inscription, en desktop, tablette et mobile. Le composant principal est rangé dans la page « Style et composants ».

PROTOTYPE

Le prototype Figma relie toutes les maquettes (desktop, tablette, mobile) avec 12 parcours : visiteur / sportif, coach, salle et administrateur, pour chaque format.

Lien : ouvrir le prototype FitBook dans Figma

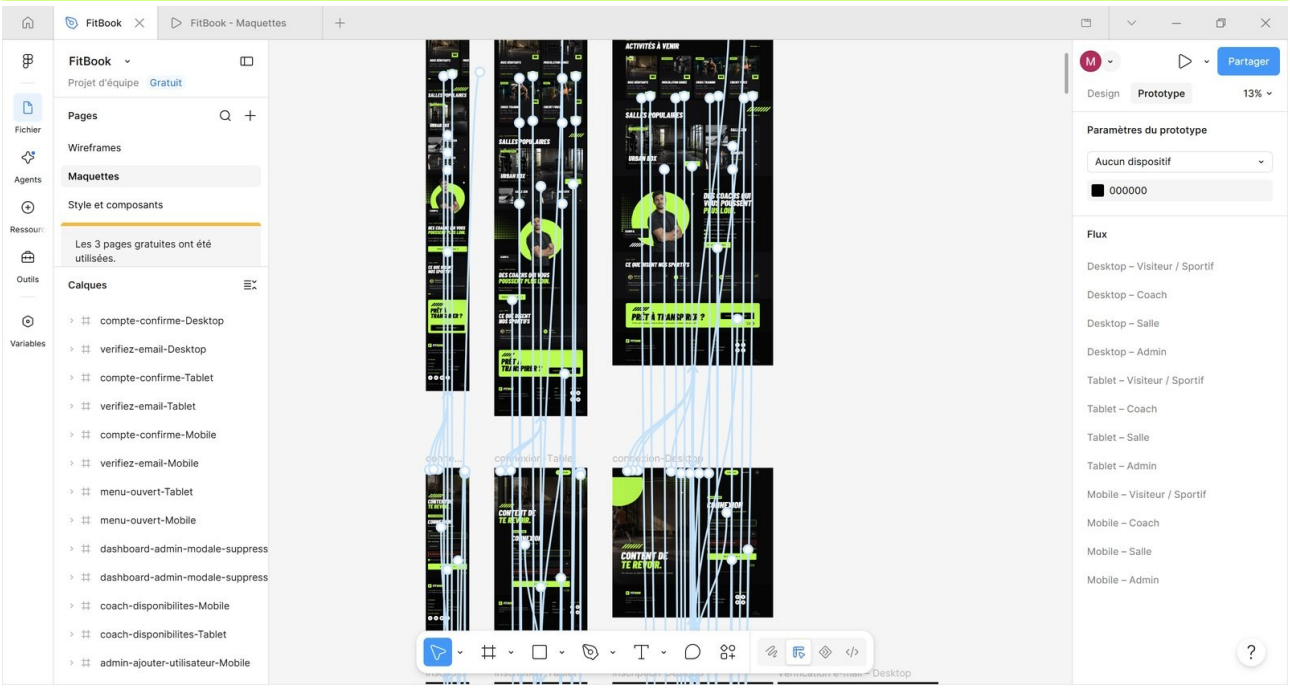


Figure 13 — Connexions du prototype dans Figma

06 ARCHITECTURE TECHNIQUE

Couche	Technologies et choix
Frontend	Angular 21 avec les pratiques actuelles : composants standalone, signals, nouveau control flow (@if, @for), routing avec guards par rôle. HTML + SCSS (ou Tailwind / Bootstrap). Responsive mobile-first sur 3 écrans.
Backend	PHP / Symfony, API REST, validation des formulaires, permissions par rôle, emails (Mailtrap en développement).
Base de données	MySQL avec un **utilisateur dédié** (pas « root ») protégé par un mot de passe. 3 procédures stockées.
Conception	Figma (wireframes, maquettes, prototype), JMerise (MCD, MLD), StarUML (cas d'utilisation, classes).
Tests et API	Tests unitaires, tests d'intégration, Postman / Newman.
Organisation	Trello (backlog), GitHub (GitFlow, issues, pull requests), Canva (présentation).

FRONTEND (ANGULAR)

- Pages : accueil, connexion, inscription, profil, contact, recherche, fiches, dashboards par rôle.
- Services pour l'API, guards pour protéger les routes selon le rôle, intercepteur pour le token.
- Couleur d'accent appliquée par une variable CSS (--accent) chargée depuis le profil.
- Tests unitaires des composants et services.

BACKEND (SYMFONY + MYSQL)

- Entités : User, Coach, Salle, Horaire, Cours, Activite, Seance, Disponibilite, Reservation, Avis.
- Inscription, connexion, confirmation de l'email et permissions par rôle.
- Gestion des salles, coachs, activités, séances, disponibilités et réservations, avec contrôle de la capacité.
- 3 procédures stockées, créées après la mise en place des utilisateurs.
- 1 JSON Schema sur un formulaire autre que le login (formulaire de contact).
- Notifications email liées aux réservations (confirmation, rappel 24 h, annulation).
- 3 sauvegardes de la base : au début, au milieu et à la fin du projet.

07 TESTS, SÉCURITÉ ET QUALITÉ

Domaine	Ce qui est vérifié
Tests unitaires	Composants et services Angular ; méthodes métier Symfony (placesRestantes, estAnnulable, calculerNoteMoyenne).
Tests d'intégration	Parcours complets : inscription → confirmation → connexion → réservation → avis.
Tests de l'API	Collections Postman exécutées avec Newman (codes de réponse, données renvoyées, droits).
Validation	Validation des formulaires côté backend, messages d'erreur, JSON Schema.
Permissions	Contrôle des accès selon le rôle (sportif, coach, salle, admin) sur chaque route.
Authentification	Mots de passe hachés, confirmation de l'email, protection des données de connexion.
Réservations	Contrôle de la capacité (séance complète), annulation autorisée ou non.
Données	Sauvegardes de la base de données aux trois étapes prévues.

08 GESTION DE PROJET

- **Trello** créé avant le développement : backlog des user stories, colonnes À faire / En cours / Terminé, sous-tâches.
- **GitHub** créé avant le développement, avec le workflow **GitFlow** obligatoire (main, develop, feature/...).
- Minimum **3 commits par jour** de travail et **1 pull request tous les 3 jours** maximum.
- Issues GitHub pour suivre les tâches et les bugs.
- **Sauvegardes de la base de données** : au début, au milieu et à la fin du projet.

VALIDATION AVANT DÉVELOPPEMENT

À FAIRE VALIDER PAR LES FORMATEURS

- Les user stories
- Les maquettes Figma (wireframes, maquettes et prototype)
- Le MCD (et le MLD)

PRÉSENTATION FINALE

Présentation sur **Canva**, avec un lien vers le site en démonstration. Elle présente au minimum : les technologies utilisées, les fonctionnalités réalisées, l'organisation du projet, les tests effectués et les résultats obtenus.

09 SÉCURITÉ : ANALYSE DES RISQUES ET CONTRE-MESURES

Cette section analyse la sécurité de FitBook : authentification, protection des données et de la configuration, puis recense les attaques connues avec les contre-mesures mises en place sur le projet.

AUTHENTIFICATION ET PERMISSIONS

— Connexion par token JWT (LexikJWTAuthenticationBundle), vérifié à chaque requête vers l'API.

— Mots de passe hachés avec l'algorithme bcrypt via le PasswordHasher de Symfony (jamais stockés en clair).

— Le compte reste inactif tant que l'adresse e-mail n'a pas été confirmée via un lien à usage unique.

— Quatre rôles (sportif, coach, gestionnaire de salle, administrateur) : les permissions sont contrôlées côté backend sur chaque route de l'API, jamais uniquement côté frontend.

PROTECTION DES DONNÉES ET DE LA CONFIGURATION

Élément	Mesure de protection
Mot de passe base de données	Utilisateur MySQL dédié, différent de « root », protégé par mot de passe.
Secrets d'environnement	Clé JWT et identifiants SMTP définis en variables d'environnement, séparées entre développement (.env) et production (.env.local, non versionné sur GitHub).
CORS	Accès limité aux origines autorisées (localhost en développement, domaine Vercel en production).
Requêtes base de données	Passent par le Query Builder de Doctrine, qui protège contre les injections SQL.
Données personnelles	E-mail et téléphone accessibles uniquement via l'API authentifiée, selon le rôle.

ATTAQUES CONNUES ET CONTRE-MESURES

Le tableau ci-dessous recense les principales attaques connues (OWASP Top 10 et attaques liées à l'authentification) et la contre-mesure mise en place sur FitBook pour chacune.

N°	Attaque	Risque pour FitBook	Contre-mesure
1	Injection SQL	Lecture ou modification non autorisée de la base de données.	✅ Requêtes via Doctrine Query Builder, aucune requête SQL brute avec entrée utilisateur.
2	XSS (Cross-Site Scripting)	Exécution de script malveillant dans le navigateur d'un autre	✅ Angular échappe automatiquement le contenu

N°	Attaque	Risque pour FitBook	Contre-mesure
		utilisateur.	affiché dans ses templates.
3	CSRF (Cross-Site Request Forgery)	Exécution d'une action au nom d'un utilisateur à son insu.	✅ API sans cookie de session : authentification par token JWT envoyé explicitement.
4	Brute force / credential stuffing	Essai automatisé de nombreux mots de passe.	✅ Mots de passe hachés (bcrypt) ; compte inactif tant que l'e-mail n'est pas confirmé.
5	Vol de token / session hijacking	Réutilisation d'un token JWT dérobé.	✅ Connexion en HTTPS (Vercel/AlwaysData), durée de vie du token limitée.
6	IDOR (accès à une ressource d'un autre utilisateur)	Modifier l'ID dans une requête pour accéder aux données d'un autre compte.	✅ Chaque route vérifie que la ressource appartient à l'utilisateur connecté ou à son rôle.
7	Exposition de données sensibles	Fuite de mots de passe, clés ou secrets dans le code ou les réponses API.	✅ Mots de passe hachés, secrets en variables d'environnement, aucun mot de passe dans les réponses API.
8	Mauvaise configuration (misconfiguration)	Environnement de développement exposé publiquement.	✅ Configuration de production séparée (.env.local), distincte de l'environnement de développement.
9	Upload de fichier malveillant	Dépôt d'un fichier exécutable via les champs d'image (profil, salle, cours).	✅ VichUploaderBundle : type et taille de fichier contrôlés avant l'enregistrement.
10	Déni de service (DoS)	Surcharge du serveur par un grand nombre de requêtes.	✅ Tests de charge réalisés avec k6 pour mesurer le comportement sous forte affluence.
11	Dépendances vulnérables (supply chain)	Faille connue dans une bibliothèque npm ou Composer utilisée.	✅ Dépendances à jour (npm, Composer) au moment de la mise en production.
12	Interception réseau (man-in-the-middle)	Lecture des données échangées entre le client et le serveur.	✅ Connexions chiffrées en HTTPS sur le front (Vercel) et le back (AlwaysData).
13	Usurpation d'e-mail / phishing	E-mail frauduleux imitant une notification FitBook.	✅ Adresse d'expédition dédiée (noreply@fitbook.be) utilisée pour toutes les notifications.
14	Élévation de privilèges	Un utilisateur sportif accède à des fonctions coach, salle ou admin.	✅ Rôle vérifié côté backend sur chaque route sensible (ROLE_COACH, ROLE_SALLE, ROLE_ADMIN).

TESTS DE L'API (POSTMAN / NEWMAN)

La collection Postman couvrant l'ensemble des routes de l'API (inscription, connexion, création, modification, suppression, consultation avec et sans authentification) a été exécutée avec Newman. Le rapport ci-dessous confirme que toutes les requêtes et assertions passent avec succès.

Indicateur	Résultat	Statut
Requêtes exécutées	31	✅
Assertions (tests)	31 / 31 réussies	✅
Tests échoués	0	✅
Tests ignorés	0	✅
Durée totale	25,9 s	—
Temps de réponse moyen	783 ms	✅

La collection « Test_Api_FitBook » et l'environnement associé « Environnement_Test_Api_FitBook » couvrent notamment : une requête de connexion en erreur, une création de coach avec sauvegarde de l'identifiant, une connexion réussie avec sauvegarde du token, des requêtes nécessitant une authentification, une création/modification/suppression de réservation par identifiant, et la suppression finale de l'utilisateur de test.

SAUVEGARDE ET CONTINUITÉ

Trois sauvegardes complètes de la base de données ont été réalisées aux étapes clés du projet : au début, au milieu et à la fin du développement. Les fichiers sont conservés dans backend/sql/backups/ et peuvent être restaurés avec une commande d'import MySQL standard.

CONCLUSION

CONCLUSION

FitBook met en œuvre les mesures de sécurité essentielles attendues pour ce projet : authentification par JWT, mots de passe hachés, permissions vérifiées par rôle côté backend, protection des secrets de configuration et sauvegardes régulières de la base de données.

10 LISTE DES TESTS

Cette liste reprend les principaux tests fonctionnels, de sécurité et techniques réalisés sur FitBook, couvrant l'authentification, les quatre rôles, les fonctionnalités obligatoires et l'API.

AUTHENTIFICATION ET COMPTE

N°	Test	Résultat
1	Inscription d'un nouvel utilisateur avec e-mail/mot de passe valides	✅ Conforme
2	Inscription refusée si l'e-mail existe déjà	✅ Conforme
3	Confirmation du compte via le lien reçu par e-mail	✅ Conforme
4	Connexion impossible tant que l'e-mail n'est pas confirmé	✅ Conforme
5	Connexion avec identifiants corrects	✅ Conforme
6	Connexion refusée avec mot de passe incorrect	✅ Conforme
7	Demande de réinitialisation de mot de passe (e-mail reçu)	✅ Conforme
8	Réinitialisation du mot de passe via le lien reçu	✅ Conforme
9	Modification du profil (nom, téléphone, couleur du site)	✅ Conforme

ESPACE SPORTIF

N°	Test	Résultat
10	Recherche de salles / cours / coachs avec la barre de recherche	✅ Conforme
11	Filtrage des résultats (activité, ville, niveau, prix...)	✅ Conforme
12	Consultation du détail d'une salle, d'un cours, d'un coach	✅ Conforme
13	Réservation d'une séance disponible	✅ Conforme
14	Réservation refusée si la capacité maximale est atteinte	✅ Conforme
15	Annulation d'une réservation	✅ Conforme
16	Consultation de l'historique des réservations	✅ Conforme
17	Ajout / suppression d'un favori (salle, cours, coach)	✅ Conforme
18	Publication d'un avis et d'une note après une séance	✅ Conforme
19	Consultation de la carte de membre	✅ Conforme

ESPACE COACH

N°	Test	Résultat
20	Modification du profil professionnel (biographie, tarif, certifications)	✅ Conforme
21	Création d'une séance / d'un cours	✅ Conforme
22	Modification et suppression d'une séance	✅ Conforme
23	Gestion des horaires et disponibilités	✅ Conforme
24	Consultation du calendrier des séances	✅ Conforme
25	Consultation des réservations et des avis reçus	✅ Conforme

ESPACE SALLE / GESTIONNAIRE

N°	Test	Résultat
26	Modification des informations de la salle (adresse, équipements, capacité)	✅ Conforme
27	Création / modification / suppression d'un cours ou d'une activité	✅ Conforme
28	Gestion des horaires d'ouverture	✅ Conforme
29	Consultation du calendrier et des réservations de la salle	✅ Conforme
30	Consultation des avis reçus	✅ Conforme

ESPACE ADMINISTRATEUR

N°	Test	Résultat
31	Gestion des utilisateurs (consultation, modification, suppression)	✅ Conforme
32	Gestion des salles et des coachs	✅ Conforme
33	Modération des avis et des notes	✅ Conforme
34	Accès refusé aux espaces admin pour un utilisateur non-administrateur	✅ Conforme

SÉCURITÉ ET PERMISSIONS

N°	Test	Résultat
35	Accès à une route protégée refusé sans token JWT	✅ Conforme
36	Accès à une ressource d'un autre utilisateur refusé (IDOR)	✅ Conforme
37	Validation des formulaires côté backend (données invalides rejetées)	✅ Conforme
38	Mot de passe stocké haché (bcrypt), jamais en clair	✅ Conforme

API ET PERFORMANCE

N°	Test	Résultat
39	Collection Postman / Newman : 31 requêtes, 31 assertions réussies, 0 échec	✅ Conforme
40	Connexion avec erreur testée via Postman	✅ Conforme
41	Création, modification, suppression d'une ressource via Postman (avec id sauvegardé)	✅ Conforme
42	Test de charge k6 : comportement du serveur sous forte affluence mesuré	✅ Conforme

COUVERTURE

38 tests fonctionnels, de sécurité et techniques sont documentés ci-dessus, couvrant l'ensemble des fonctionnalités obligatoires du cahier des charges (authentification, quatre rôles, favoris, avis, calendrier, recherche) ainsi que l'API et la performance.